

RCE on Supabase

Platform:

Supabase is an open-source backend-as-a-service (BaaS) platform that provides developers with a scalable and secure alternative to Firebase. It is built on top of PostgreSQL and offers a full suite of backend capabilities, including database, authentication, real-time subscriptions, file storage, serverless functions, and RESTful/GraphQL APIs. Supabase enables developers to rapidly build modern web and mobile applications with minimal backend development effort.

Note: The instance used for attack is a free-tier supabase database hosted on AWS.
(<https://supabase.com/>)

Class:

Remote Code Execution

Summary:

We discovered a privilege-escalation vulnerability in the Supabase-supported extension **supabase_vault**, which allowed us to obtain **superuser privileges** and subsequently achieve **command execution** inside hostvm by leveraging the **file_fdw** extension.

Note: Due to time and resource constraints, there may be undiscovered risks through this RCE risk.

Attack Description:

Get RCE on hostvm

First, create a supabase database instance hosted on azure, then connect to it. Drop extension **supabase_vault** extension, and create it again with version '0.2.8', with extension **pgsodium supported**. We can get all control of table **vault.secrets**. After that, insert a **trigger on vault.secrets**, use function **vault.create_secret to invoke the trigger**, thereby gaining superuser access showed in **Figure 1**.

	A-Z rolname	☒ rolsuper	☒ rolinherit	☒ rolcreatorole	☒ rolcreatedb
▶ 11	pg_signal_backend	[]	[v]	[]	[]
▶ 12	pg_checkpoint	[]	[v]	[]	[]
▶ 13	pg_maintain	[]	[v]	[]	[]
▶ 14	pg_use_reserved_co	[]	[v]	[]	[]
▶ 15	pg_create_subscripti	[]	[v]	[]	[]
▶ 16	dashboard_user	[]	[v]	[v]	[v]
▶ 17	authenticated	[]	[v]	[]	[]
▶ 18	anon	[]	[v]	[]	[]
▶ 19	service_role	[]	[v]	[]	[]
▶ 20	supabase_admin	[v]	[v]	[v]	[v]
▶ 21	authenticator	[]	[]	[]	[]
▶ 22	supabase_auth_admini	[]	[]	[v]	[]
▶ 23	supabase_storage_ac	[]	[]	[v]	[]
▶ 24	supabase_replication	[]	[v]	[]	[]
▶ 25	supabase_etl_admin	[]	[v]	[]	[]
▶ 26	supabase_read_only_	[]	[v]	[]	[]
▶ 27	pgbouncer	[]	[v]	[]	[]
▶ 28	supabase_realtime_a	[]	[]	[]	[]
▶ 29	pgsodium_keyiduser	[]	[v]	[]	[]
▶ 30	pgsodium_keyholder	[]	[v]	[]	[]
▶ 31	pgsodium_keymaker	[]	[v]	[]	[]
▶ 32	postgres	[v]	[v]	[v]	[v]

Figure1: make user default role neondb_owner with superuser

By leveraging the features of extension `file_fdw` , command execution can be achieved like in **Figure 2**.

select * from foreign_tb1 | Enter a SQL expression to filter results (use Ctrl+Space)

	AZ	t
126	postgres	1651 0.0 4.0 269346248 17008 ? Ssl Dec05 3:41 /opt/postgres/etc/postgres/merged.conf
127	envoy	1673 0.0 0.5 19068 2460 ? Ss Dec05 0:00 python3 /opt/envoy-hot-restarter.py /opt/start-envoy.sh
128	envoy	1685 0.0 0.3 7056 1516 ? S Dec05 0:00 bash /opt/start-envoy.sh
129	envoy	1688 0.2 3.3 2268552 13972 ? Sl Dec05 8:29 /opt/envoy --config-path /etc/envoy/envoy.yaml --restart-epoch
130	envoy	1689 0.0 0.3 5272 1300 ? S Dec05 0:00 tee
131	postgres	1741 0.0 0.4 354244 1888 ? Ss Dec05 0:00 postgres: main: authenticator postgres ::1(58789) idle
132	root	2449 0.1 6.4 847128 27184 ? Ssl Dec05 5:19 /usr/bin/python3 /usr/bin/fail2ban-server -xf start
133	root	2637 0.0 0.3 7056 1444 ? Ss Dec05 0:00 /bin/bash -c tcpdump -s 128 -Q out -nn -tt -vv -p -l 'tcp and (port
134	tcpdump	2638 0.0 1.3 18200 5896 ? S Dec05 0:00 tcpdump -s 128 -Q out -nn -tt -vv -p -l tcp and (port 5432 or p
135	root	2639 0.0 1.1 20168 5008 ? S Dec05 0:02 perl /root/pg_egress_collect.pl
136	root	2680 0.0 0.0 0 0 ? l< Dec05 0:00 [kworker/R-ib-comp-wq]
137	root	2681 0.0 0.0 0 0 ? l< Dec05 0:00 [kworker/R-ib-comp-unb-wq]
138	root	2682 0.0 0.0 0 0 ? l< Dec05 0:00 [kworker/R-ib_mcast]
139	root	2683 0.0 0.0 0 0 ? l< Dec05 0:00 [kworker/R-ib_nl_sa_wq]
140	postgres	2732 0.0 3.2 1237032 13520 ? Ssl Dec05 0:25 /opt/postgres_exporter/postgres_exporter --disable-settings-
141	root	2777 0.0 0.0 0 0 ? S Dec05 0:00 [psimon]
142	vector	2787 0.1 5.4 240532 22876 ? Ssl Dec05 6:29 /usr/bin/vector --config-yaml /etc/vector/vector.yaml
143	vector	2800 0.0 1.6 118292 7144 ? S Dec05 0:02 journalctl --follow --all --show-cursor --output=json --boot --aft
144	vector	2801 0.0 1.6 118292 7084 ? S Dec05 0:03 journalctl --follow --all --show-cursor --output=json --boot --aft
145	vector	2802 0.0 1.7 118640 7188 ? S Dec05 0:03 journalctl --follow --all --show-cursor --output=json --boot --aft
146	vector	2803 0.0 1.6 118900 7100 ? S Dec05 0:03 journalctl --follow --all --show-cursor --output=json --after-curs
147	vector	2804 0.0 1.6 118640 7060 ? S Dec05 0:03 journalctl --follow --all --show-cursor --output=json --boot --af
148	postgres	2827 0.0 3.2 357808 13580 ? Ss Dec05 1:02 postgres: main: supabase_admin postgres ::1(3677) idle
149	postgres	5092 0.0 0.4 354408 2076 ? Ss Dec05 0:00 postgres: main: supabase_admin postgres ::1(62889) idle

Figure2: execute command "ps aux"

We did **not proceed any further**. We believe that stopping at this point was appropriate, as going deeper could have caused **unnecessary disruption** to Supabase' s service operations.

Usage:

We include the SQL that achieves RCE, named **poc.sql**, in the appendix.

Thinking:

In multi-tenant database scenarios on the cloud, cross-tenant attacks and defenses are typically multi-layered. In this case, the RCE vulnerability may enable attackers to explore and carry out potential cross-tenant hijacking attacks.

Acknowledgement:

This vulnerability was discovered by the **Volcano Engine Cloud Security Team**.